ACCIONES CORRECTIVAS PREVENTIVAS Y DE MEJORAMIENTO

One Language

Proyecto formativo ADSO-3145555 | Version de trabajo: 1.0 | Fecha: 4 de noviembre de 2026

Proposito y criterio

Este registro convierte las brechas tecnicas identificadas en trabajo verificable. “Verificado localmente” no significa que el cambio este en produccion. Los estados deben actualizarse despues de revisar CI, PR y despliegue. La rotacion de credenciales productivas se asigna al administrador propietario de correo, VPS y base de datos; no se incluyen secretos ni se ejecuta una rotacion no coordinada.

1. Acciones correctivas

AC-01 | Prioridad critica | Secretos expuestos en historial o configuracion. Accion: el propietario rota JWT_SECRET, contraseña de aplicacion de correo y credencial PostgreSQL en todos los entornos; actualizar variables de servicios y CI; invalidar valores anteriores; purgar historial con aprobacion y coordinar reclonado de forks. Evidencia: valores antiguos rechazados, escaneo de historial limpio y secretos solo en entorno/CI. Estado: asignado al propietario de las credenciales; pendiente de evidencia final.

AC-02 | Prioridad alta | Configuracion de proxy/origenes y puertos entre web, movil e IA. Accion: usar puertos y URLs coherentes en Vite, network.ts, ejemplos y Compose; probar WebSocket en origen local previsto y produccion. Evidencia: prueba de humo automatizada desde web/movil y configuracion de origen explicita. Estado: confirmar en CI y con la version actual de ramas.

AC-03 | Prioridad alta | Imagen web de produccion debe enrutar API y aplicar CSP compatible. Accion: proxy Nginx para /api y /auth; CSP connect-src limitado a dominios reales necesarios. Evidencia: imagen construida y ejecutada, login contra backend, sin 404/CSP. Estado: imagen de produccion construida localmente y cabeceras observadas; repetir login integrado en cada release.

AC-04 | Prioridad alta | WebSocket IA requiere controles de acceso y limites. Accion: exigir JWT, rechazar Origin ausente/no permitido, limitar conexiones y tamaño/frecuencia de frames por IP, cerrar con codigo apropiado y registrar sin tokens. Evidencia: pruebas automatizadas de token ausente, origen ausente, limite excedido y cliente autorizado. Estado: pendiente de prueba automatizada y revision de implementacion.

AC-05 | Prioridad media | Cobertura de backend y base de datos. Accion: integrar pruebas de API contra PostgreSQL real/temporal, reportar cobertura JaCoCo y hacer que CI falle bajo el umbral acordado. Evidencia: pipeline en rama remota, logs de ejecucion y reporte de cobertura. Estado: suite local aprobada; rama test/postgres-integration-ci contiene cambios locales pendientes de PR y no se declara publicada.

AC-06 | Prioridad media | Desfase entre esquema SQL y modelo de accesibilidad. Accion: decidir si voice_feedback se integra en entidad/DTO/servicio o se elimina mediante migracion; actualizar manual y pruebas. Evidencia: esquema y modelo alineados, migracion aprobada y prueba de lectura/escritura.

2. Acciones preventivas

AP-01 | Cada release | Ejecutar escaneo de secretos en commits y artefactos, revisar archivos .env, bundles y logs; mantener gitleaks en CI.

AP-02 | Cada PR a qa/main | Requerir al menos una revision aprobada, checks verdes y relacion del PR con historia/issue. Mantener tablero con responsable, prioridad y estado.

AP-03 | Seguridad | Separar credenciales por ambiente, limitar privilegios de PostgreSQL, no publicar el puerto de base de datos y rotar credenciales con plan de invalidacion y rollback.

AP-04 | Despliegues | Mantener healthchecks, respaldos comprobados, version de imagen/commit, prueba smoke y procedimiento de rollback; validar permisos y uso de usuario no root.

AP-05 | WebSocket y privacidad | Limitar origen, tamaño de mensaje, concurrencia y frecuencia; no guardar video completo por defecto; minimizar datos personales en logs y definir retencion de grabaciones opcionales.

3. Acciones de mejoramiento del software

AM-01 | IA | Medir precision, recall, matriz de confusion y latencia por seña y dispositivo; aumentar diversidad de datos y documentar limites antes de ampliar etiquetas. No publicar porcentaje de exactitud sin protocolo reproducible.

AM-02 | Producto | Mejorar mensajes de reconexion, estado de permisos y errores de camara/microfono; probar accesibilidad, tamaños de pantalla y conectividad de Expo en dispositivos reales.

AM-03 | Persistencia | Revisar indice de historial con EXPLAIN, filtros recientes/todos/favoritos y limites de paginacion; conservar indices y migraciones revisables.

AM-04 | Operacion | Automatizar despliegue coordinado de servicios sin asumir un Compose monolitico; incluir healthcheck, usuario no root, URL de servicio, respaldo y rollback probado.

AM-05 | Documentacion | Versionar vision, alcance, KPIs, historias con criterios de aceptacion, diagramas, manuales y evidencia de pruebas; enlazar cada criterio a pantalla o endpoint.

4. Priorizacion y seguimiento

Primero resolver exposicion de credenciales y acceso no autorizado (AC-01 y AC-04). Luego asegurar la ruta web/API/IA y pruebas de release (AC-02, AC-03 y AC-05). Finalmente cerrar consistencia de datos y mejoras del producto (AC-06, AM-01 a AM-05). Cada accion debe tener un responsable nominal, fecha objetivo, issue y evidencia antes de marcarse completa.

5. Indicadores de cierre sugeridos

Seguridad: cero secretos activos en historial y cero hallazgos de secretos en escaneo de main.

Calidad: CI verde, pruebas de API/PostgreSQL ejecutadas y umbral de cobertura acordado respetado.

Operacion: healthchecks saludables, release identificable y rollback probado en un entorno controlado.

Producto: tareas de usuario criticas completadas sin error; medicion de latencia/precision de IA con conjunto de evaluacion versionado.

6. Registro de cambios

La suite local del backend verificada el 4 de noviembre de 2026 ejecutó 41 pruebas con cero fallos; seis pruebas E2E/concurrencia se habilitaron separadamente contra PostgreSQL temporal y pasaron. Liquibase aplicó 21 changesets en esa base temporal. Esto aporta evidencia de pruebas locales, pero no sustituye la ejecución de CI ni la aprobación de PR.